

BEC / invoice-fraud response

Business Email Compromise · **High** severity · SOC IR Playbook

Severity

High

Detection & Analysis

- **Verify the fraud** — Confirm the suspicious payment/redirect request and the look-alike domain or compromised mailbox.

Containment

- **Stop the money & access** — Initiate bank recall if a payment went out; reset the mailbox, revoke sessions, remove inbox rules.

Eradication

- **Clear persistence** — Remove forwarding/transport rules and OAuth grants; hunt for other affected mailboxes.

Recovery

- **Re-secure finance flow** — Re-enable accounts with MFA; reinforce out-of-band payment verification.

Post-Incident

- **Report & train** — File with law enforcement, brief finance/leadership, update the verification control.